Méthodes sans LLM pour LANCE

Références fortes et programme de mesure pour le comité de thèse

Synthèse Codex de trois recherches spécialisées

Projet LANCE ; contre-relecture par des agents distincts des auteurs

Dernière révision : 2026-10-07 14:44 (Europe/Brussels, UTC+02:00)

Recherche exploratoire et protocole proposé ; aucun gain expérimental établi

Résumé

La réussite d'un audit utilisant un modèle de langage ne mesure pas l'apport du modèle. Cette recherche examine les références sans LLM qui permettraient de répondre à l'objection du comité de thèse. Trois revues ciblées étudient les méthodes déterministes, le raisonnement classique et les expériences recevables. La priorité proposée est une référence conditionnelle compétente, évaluée sur des dossiers et critères communs ; une procédure fixe reste un contraste secondaire. Jointures, moteurs de politiques et vérification de configurations sont retenus seulement si les données et la propriété les justifient. Six expériences hors ligne séparent qualité des conclusions, fausses alertes, contexte, robustesse et utilité du rapport. Une contre-relecture impose un gel de la référence, un univers indépendant des candidats LANCE et des coûts humains complets. Les documents décrivent une méthode de mesure, sans résultat de supériorité ni d'équivalence ; une décision favorable aux règles seules reste scientifiquement recevable.

Table des matières

1 Question : mesurer un effet marginal utile **2**

2 Méthode et statut des preuves **2**

3 Références simples : sélectionner la bonne tâche **3**

4 D1 existe déjà : préserver les contrastes **4**

5 Six expériences et premières priorités **4**

6 Ce qu'il faut mesurer pour pouvoir conclure **5**

7 Coûts et décisions recevables **6**

8 Travail à préparer et limites **7**

9 Conclusion **8**

Références **8**

1 Question : mesurer un effet marginal utile

LANCE réalise des audits de sécurité d'objets connectés (IoT). Il combine des outils, des règles et des modèles de langage (LLM). La question du comité est : **sur quelles tâches le LLM apporte-t-il un bénéfice utile, au-delà d'une méthode simple correctement conçue, et à quel coût ?** Déclarer que le système complet trouve des problèmes ne répond pas à cette question.

La contribution de thèse envisageable devient une décomposition empirique : quelles décisions sont déjà résolues par les règles, où subsiste une difficulté, et si le modèle améliore cette difficulté avec des preuves vérifiables. Cette formulation est une proposition de recherche, pas une revendication de nouveauté mondiale. Le protocole historique distingue déjà interprétation, adaptation et restitution [1] ; l'approfondissement précise surtout la force des comparateurs classiques et les conditions de leur sélection. SQL désigne le langage de requêtes relationnelles ; Datalog, un langage de règles logiques. OPA est l'Open Policy Agent, et Cedar un langage de politiques. HSA signifie *Header Space Analysis*. Les autres noms du tableau sont des outils ou des formats, décrits dans les rapports spécialisés.

Sans LLM ne signifie pas sans adaptation. Un programme peut utiliser des conditions, de l'état, des relations et une politique d'abstention sans apprentissage. Sans LLM ne signifie pas non plus sans IA : l'apprentissage statistique classique appartient à cette catégorie, mais demande des données et une validation qui ne le rendent pas automatiquement plus simple.

2 Méthode et statut des preuves

2.1 Recherche organisée et lectures

L'étude conserve le dossier commencé le 27 septembre 2026. L'approfondissement du 7 octobre répartit trois tâches entre agents : outils déterministes [2], raisonnement classique [3], et programme d'expériences [4]. Des agents distincts des auteurs assurent la contre-relecture du texte et des pages rendues. Le journal validation.md identifie les versions, objections, corrections et limites réellement relues.

Les sources sont primaires : spécifications, documentations officielles et articles des auteurs. La sélection est ciblée, non systématique ; elle vise les entrées nécessaires, la transformation produite, la portée des conclusions et les conditions d'évaluation. Chaque registre spécialisé précise les sections lues, date ou version, consultation et limites. Les articles ne sont pas reproduits ; les résultats de corpus hétérogènes ne sont pas classés ensemble. Le registre sans-llm-sources.json réunit ces lectures et les sources complémentaires de la présente synthèse.

La lecture NIST SP 800-115, sections 3.3–3.4, justifie notamment une référence de revue de règles et de configurations, avec collecte et accès explicités [5]. SP 800-53A, section 2.4, relie objets, méthode, couverture et critère d'évaluation [6]. Leur transfert aux fiches LANCE est notre proposition ; il ne constitue ni certification, ni validation de LANCE.

2.2 État local et faits observables

Le commit de base est a8dbeb9404f0cad960d61e42f02a1d70ca143a59, avec modifications et conflits locaux. Les empreintes des lectures figurent dans les registres spécialisés. La lecture du code est statique ; aucun import applicatif, campagne, appel LLM de benchmark ou collecte réseau n'a été réalisé. Les conflits empêchent de présumer que cette copie s'exécute ou représente le déploiement. Les résultats historiques restent attribués à leurs dates.

Nous distinguons *fait sourcé*, *fait de lecture statique*, *hypothèse* et *protocole proposé*. La compilation et l'inspection des PDF vérifient les documents ; elles ne mesurent pas la valeur du modèle.

3 Références simples : sélectionner la bonne tâche

3.1 Ne pas confondre les objets évalués

Un inventaire de service, un avis concernant un produit, une règle de configuration et une observation de comportement établissent des faits différents [2]. Une correspondance de version peut justifier une applicabilité selon un avis ; elle ne prouve pas un impact observé. Une politique d'autorisation calcule un droit attendu ; sa décision ne prouve pas que l'équipement applique ce droit. Une vérification formelle est exacte sur son modèle, sous réserve que ce modèle décrive correctement les données.

Le critère d'audit doit donc préciser propriété, ressource, identité, contexte, période et preuve requise. L'absence d'une donnée ne devient pas un état sain. L'absence d'un tuple SQL, une valeur NULL ou une règle non déclenchée n'établit pas à elle seule la complétude. Une déclaration explicite de couverture et une politique d'abstention sont nécessaires [3].

3.2 Ordre proposé et conditions d'entrée

Le tableau 1 propose une progression. L'ordre exprime la compatibilité avec les dossiers disponibles et la lisibilité des erreurs, sans estimation chiffrée de charge ni classement de performances.

Référence	Ce qu'elle permet de tester	Condition / décision proposée
Checklist fixe, D0	Application systématique de critères explicites.	Contraste secondaire ; critères compétents, inconnus conservés.
Règles conditionnelles	Contexte, exceptions, contradictions et abstention.	Référence principale ; D1 existant ou lecteur hors ligne proposé, selon tâche.
Jointures SQL	Attribution, rapprochement de pièces et traçabilité.	Ajouter si les relations l'exigent ; même politique de décision.
Datalog / Soufflé	Interdépendance des règles et provenance d'inférences.	Option après SQL ; la récursion existe aussi en SQL.
Table de droits, OPA ou Cedar	Calcul d'une autorisation attendue et comparaison à une observation.	Politique propriétaire disponible ; table simple avant moteur spécialisé.
Matching inventaire–avis	Applicabilité sous identité et conditions connues.	Inventaire crédible et avis figés ; abstention si contexte insuffisant.
OVAL / OpenSCAP	Conformité à un profil sur export local compatible.	Profil adapté et mêmes pièces locales dans les deux bras.
FIREMAN, HSA, Batfish	Propriétés d'un modèle de configuration réseau.	Piste séparée ; exports supportés et question précise indispensables.

Table 1 – Références proposées par tâche. Les outils externes et le lecteur hors ligne ne sont pas annoncés comme intégrés dans LANCE.

Nmap ou des matchers et workflows de contrôles bénins constituent des implémentations classiques pertinentes pour certaines propriétés [2]. Comparer leur utilité complète à LANCE peut être utile, à condition de publier leurs couvertures et accès respectifs. Cela ne suffit pas à isoler l'effet du LLM. OpenSCAP et les avis liés aux inventaires logiciels SBOM (*Software Bill of Materials*) et au format CSAF (*Common Security Advisory Framework*) changent aussi l'information disponible lorsque les configurations ou inventaires logiciels ne sont pas remis aux deux bras.

Le premier pilote écarte l'apprentissage classique faute de labels indépendants identifiés, les moteurs spécialisés firmware faute d'artefacts adaptés, et NetPlumber faute de question sur les mises à jour. Ces exclusions sont des décisions de périmètre ; elles ne prouvent aucune faiblesse de ces méthodes. Leur retour devient recevable lorsqu'une question et ses données sont disponibles [3].

4 D1 existe déjà : préserver les contrastes

Fait de lecture statique. D1 désigne la politique d'automatisation conditionnelle sans LLM ; A1, la politique adaptative avec LLM. Le contrat analysis-verification fixe un inventaire public, le profil full et les phases 3–4 : analyse et vérification. Le scanner initial est partagé ; les règles participent donc déjà au succès d'A1. D1 n'est pas une référence couvrant toutes les phases de l'audit. Les sources visibles et limites de ce diagnostic sont détaillées dans [4].

Les identifiants D0, A0 et D1-R du protocole historique restent des variantes proposées, à revalider avant emploi. Un **lecteur à règles sur dossiers** est ici un adaptateur hors ligne proposé ; il ne doit pas être présenté comme le D1 actuellement implémenté. De même, une fonction de rapprochement d'avis de vulnérabilité CVE (*Common Vulnerabilities and Exposures*) visible sur un chemin compact ne prouve pas sa couverture dans l'expérience full. Ce constat est limité au chemin inspecté.

Les connaissances publiques spécifiques aux simulateurs demandent un audit de fuite. Le partage d'un oracle de production peut aussi produire des erreurs communes : le contrat de preuve LANCE ne devient pas la vérité terrain du test. Les identifiants et empreintes déclarés aident à comparer les artefacts ; ils ne certifient pas l'identité de l'état réellement observé.

4.1 Deux effets à garder séparés

Le premier contraste mesure **l'interprétation de pièces communes** : normalisation et contexte accessibles identiques, critère identique, lecteur à règles contre lecteur LLM. Il ne mesure pas la collecte. Le second mesure **l'utilité d'un système complet**, avec ses outils, accès et couverture déclarés. Il peut guider un choix pratique, mais l'attribution au LLM y demeure plus faible. Le contraste D1/A1 phases 3–4 est un ajout du modèle au socle commun ; des observations finales différentes empêchent de le réduire à une comparaison d'interprètes.

Même sans recherche externe, le préentraînement du LLM constitue une connaissance supplémentaire. Des noms et avis fictifs cohérents permettent un contrôle de mémorisation, sans prouver l'absence de toutes les fuites. Une date récente ne garantit pas que l'information soit absente du modèle. Un résultat doit donc nommer l'effet du composant LLM, plutôt que revendiquer automatiquement un raisonnement pur.

La figure 1 montre le contraste hors ligne recommandé. La sélection des pièces est indépendante des candidats produits par LANCE, afin de conserver les omissions dans l'univers évalué.



Figure 1 – Protocole proposé pour attribuer une différence d'interprétation au composant LLM. Le modèle peut conserver des connaissances préentraînées. La figure est modifiable dans cette source.

5 Six expériences et premières priorités

Les fiches complètes [4] décrivent données communes, oracle, contrôles, comparateurs, métriques, coûts et critères d'arrêt. Les expériences ci-dessous sont **proposées**, sans corpus admissible ni effectif validé.

Table 2: Programme de tests hors ligne ; priorités décidées avant lecture du test réservé.

Expérience	Contraste et exemple de dossier	Décision ou limite visée
Routine	Critère direct, pièce suffisante ou absente ; procédure fixe, règles conditionnelles et lecteur LLM.	Les règles suffisent-elles ? Ne pas rendre la procédure fixe artificiellement faible.
Cas sains / faible prévalence	Positifs, négatifs proches et propriété non documentée ; les cas sains ressemblent aux alertes.	Fausses alertes, abstention et couverture ; **priorité avec routine**.
Autorisation	Même réponse avec identité et politique différentes ; politique absente ou contradictoire.	Table de droits avant OPA/Cedar ; gain utile seulement si contexte correctement relié.
Information répartie	Pièces séparées, dates incompatibles ou contradictions ; jointures simples contre lecteur LLM.	Mesurer liaison et preuve, pas seulement accumulation de texte ; prioritaire si pièces disponibles.
Variations équivalentes	Même sémantique, ordre des champs ou formulation modifiés ; contenu incomplet séparé.	Distinguer robustesse du parseur et interprétation ; pas de handicap sélectif pour les règles.
Restitution humaine	Même ensemble de faits validés, rapport déterministe contre rédaction LLM ; revue de décisions par lecteurs.	Temps de vérification, erreurs et utilité ; gain rédactionnel distinct de la détection.

Commencer par routine et cas sains. Ces tests donnent une première estimation de la qualité, des inconnus et du coût, avec les références simples les plus crédibles. Ajouter ensuite autorisation ou information répartie si des pièces suffisantes existent. La restitution demande une procédure humaine séparée : ordre contrebalancé, décisions et temps mesurés, exposition répétée au même cas contrôlée. Aucun effectif ni seuil n'est fixé arbitrairement. Geler les faits sources ; conserver et compter les omissions et inventions dans les rapports générés. Une variation de format sur le même corpus peut compléter le pilote : l'échec de parsing reste une sortie mesurée dans la strate brute, même s'il invalide le contraste sur dossiers normalisés.

Pour un rejeu conditionnel, toutes les branches enregistrées ne suffisent pas lorsque les réponses dépendent de l'historique. Restreindre le pilote à des lectures sans effet et indépendantes de cet historique, ou à des histoires fournies cohérentes avec leur état ; sinon la tâche reste hors couverture. Les exemples synthétiques servent aux contrôles ciblés et sont signalés. Ils ne deviennent pas des résultats terrain.

6 Ce qu'il faut mesurer pour pouvoir conclure

6.1 Oracle, univers et sorties

Définir l'univers indépendant de propriétés et dossiers *avant* les candidats LANCE : inclure ce que son collecteur a omis. Sur un corpus limité aux candidats, le rappel est conditionnel et ne décrit pas l'audit complet. Pour chaque cas, l'oracle indépendant décrit deux objets : $T_{\text{état}}$, état de la propriété, et T_{preuve}, suffisance des preuves accessibles. Une propriété réellement violée peut rester non démontrable dans le dossier ; la bonne sortie est alors l'incertitude, selon le contrat préenregistré. Le problème d'oracle reste une limite générale des tests logiciels [4].

Prévoir une revue distincte, des justifications, le traitement des désaccords et le masquage de l'identité du système lorsque possible. Les évaluateurs ne réutilisent pas seulement le verdict automatique de LANCE. Conserver contradictions, erreurs techniques, dépassements et essais incomplets : les retirer peut transformer la fragilité en gain apparent.

Les mesures comprennent précision des conclusions étayées, rappel dans l'univers annoncé, fausses alertes sur cas sains, couverture des décisions, abstention justifiée et taux d'échec. Rapporter aussi la qualité des références aux pièces et le nombre de conclusions sans support. Une seule moyenne masque des erreurs différentes ; stratifier par famille préenregistrée et afficher les dénominateurs. Le rappel sur les états réellement positifs de l'univers indépendant et le rappel conditionnel aux positifs démontrables sont publiés séparément. Les cas non démontrables, abstentions et échecs restent dans les totaux et la couverture. Des strates trop petites restent descriptives. Dans une strate saine, privilégier le taux de fausses alertes avec nombre de cas réellement sains au dénominateur ; le score F1 peut être nul ou indéfini selon les sorties et la convention, sans décrire seul cette qualité.

6.2 Indépendance et incertitude

Comparer les bras sur mêmes familles et mêmes conditions. Des répétitions du modèle sur une famille ne deviennent pas autant de cas indépendants. Une famille d'origine regroupe les cas partageant générateur, implémentation, service ou structure ; leurs variantes restent dans le même groupe. Les six expériences du tableau ne sont pas six unités indépendantes. Le test réservé doit différer des données utilisées pour écrire critères, règles, prompts et sélection de modèle. Le découpage public S1–S19 / S20–S29 ne garantit pas à lui seul l'indépendance historique de ces familles. Un test réservé aux auteurs ne certifie pas son absence du préentraînement ; de nouvelles familles privées réduiraient ce risque sans le faire disparaître.

Le pilote est d'abord descriptif. Le choix des marges utiles, de la mesure principale, des garde-fous et de l'effectif précède une étude confirmatoire et dépend de la variabilité observée et de la structure des familles. Une différence non significative ne prouve pas une équivalence [7]. Une conclusion d'équivalence ou de non-infériorité demande un protocole approprié et des bornes justifiées. Un intervalle large appelle une conclusion indéterminée. Il n'est pas proposé d'appliquer mécaniquement un test prévu pour moyennes indépendantes à tous les scores ou données groupées.

7 Coûts et décisions recevables

7.1 Mesurer le travail déplacé

Les règles coûtent en critères, normalisation et maintenance ; le modèle coûte en intégration, appels, validation et correction. Les données, oracles et profils nécessaires doivent être comptés pour chaque bras. Mesurer séparément temps de développement, entretien par changement, temps de revue humaine, calcul, latence et consommation. Ne pas additionner directement heures, euros et tokens. Une monétisation éventuelle précise taux, prix et date ; l'absence de tokens ne signifie pas absence de travail.

Sur un horizon annoncé de n dossiers, une représentation proposée est

$$C(n) = C_{\text{développement}} + C_{\text{maintenance}}(n) + \sum_{i=1}^{n} (C_{\text{exécution},i} + C_{\text{revue},i}).$$

Tous les termes doivent employer la même unité si un total est calculé. Publier aussi les mesures brutes et les coûts partagés : un meilleur total peut dépendre de l'horizon et du prix retenus. Aucun point de rentabilité n'est déduit sans mesure.

7.2 Décider sans obliger le LLM à gagner

Le tableau 3 donne les issues admissibles. Ces conditions doivent être recevables avant de connaître le résultat du test.

Résultat possible, à établir	Conséquence proposée
Règles adéquates, coût inférieur, preuve de qualité suffisante	Conserver la méthode classique pour la tâche.
Gain LLM utile, garde-fous respectés, coût acceptable	Retenir le modèle pour cette tâche et les conditions mesurées.
Gain seulement sur rédaction et revue	Limiter la conclusion à la restitution ; garder les faits validés comme entrée commune.
Gain disparaissant avec règles compétentes ou avis fictifs	Réviser l'attribution ; coût de la connaissance ou mémorisation à distinguer.
Incertitude trop large, oracle ou corpus inadmissible	Ne conclure ni gain ni équivalence ; corriger la condition manquante.

Table 3 – Règles de décision proposées. « Adéquat » et « utile » demandent des seuils justifiés et fixés avant le test confirmatoire.

Un fonctionnement mixte par famille peut être envisagé seulement si son routage est fixé sur développement et évalué ensuite. Choisir pour chaque cas le vainqueur après lecture du test ne constitue pas un système déployable. La référence principale est sélectionnée et gelée avant test parmi les méthodes admissibles, sans sélection opportuniste a posteriori.

8 Travail à préparer et limites

8.1 Lots concrets avant une expérience

Le premier lot est un **registre d'éligibilité** : propriété, pièces, provenance, accès, contexte, indépendance, oracle et inconnus pour chaque famille. Il permet de refuser une comparaison non identifiable. Le deuxième lot est une **référence acceptée sur développement** : critères revus, contextes, négatifs proches, inconnus, justifications, effort humain enregistré. Geler code, corpus, avis, prompts, modèles, normalisation et configuration avant de découvrir le test ; toute nouvelle version nécessite un nouveau test réservé.

Le troisième lot est un **pilote apparié hors ligne**, avec routine et cas sains, puis contextualisation si admissible. Sa sortie est un diagnostic des erreurs, coûts et variabilité, pas une revendication confirmatoire. Le quatrième lot prépare le **test réservé** : marges utiles, plan d'analyse, familles réellement indépendantes, garde-fous et effectif justifié. La revue humaine de restitution est un lot séparé si la question devient prioritaire. Ces lots restent proposés ; aucune intégration n'est annoncée achevée.

8.2 Objections de la contre-relecture

La première contre-revue a exigé six corrections : distinguer D1 implémenté du lecteur proposé ; fixer une porte d'acceptation de la référence ; qualifier la connaissance préentraînée ; garantir un rejeu cohérent ; inclure les omissions du collecteur ; laisser la pagination suivre le contenu. Le journal conserve également les corrections de la contre-revue expérimentale : labels d'état et de preuve séparés, matrice normative légitime, erreurs de restitution conservées, conventions de F1 et échecs du parseur explicités. Il identifie les arbitrages et les versions effectivement inspectées. Les conditions non résolues concernent encore les données éligibles, l'oracle indépendant, l'indépendance des familles et les seuils utiles. Aucune relecture documentaire ne peut les déclarer expérimentalement satisfaites.

8.3 Limites de la conclusion

La recherche est ciblée et centrée sur des dossiers défensifs ; elle ne décrit pas toutes les méthodes d'audit IoT et ne mesure pas la découverte autonome. Les outils externes restent non exécutés, leurs compatibilités non établies et les coûts qualitatifs. Un gain sur dossiers synthétiques ne prouve pas un gain sur réseaux réels ; un gain d'interprétation ne prouve pas une meilleure collecte. La copie conflictuelle limite aussi les conclusions sur l'état exécutable.

9 Conclusion

La première réponse au comité est de construire une mesure qui pourrait conclure en faveur des méthodes simples. Le meilleur point de départ est une référence conditionnelle compétente, des dossiers communs et un oracle distinct du verdict produit par LANCE. Routine et cas sains précèdent les formalismes plus complexes ; jointures et politiques interviennent quand les pièces les justifient. La plus-value du LLM reste une hypothèse à tester. Démontrer qu'il est inutile sur certaines tâches, ou utile seulement pour la restitution, serait également une conclusion exploitable pour la thèse.

Références

[1] Projet LANCE, *Apport de l'agent face à l'automatisation*, étude commencée le 27 septembre 2026, rapport révisé le 1er octobre 2026 à 10 :23. Rapport historique, protocole et état de l'art ciblé. Lecture ciblée des comparateurs et conditions ; résultats historiques non reproduits.

[2] Agent sans_llm_outils, *Méthodes simples sans LLM pour l'audit IoT : références défensives et comparateurs pour LANCE*, 7 octobre 2026. Rapport et registre des lectures.

[3] Agent sans_llm_raisonnement, *Raisonnement sans LLM pour l'audit IoT : références simples, politiques et vérification de configurations*, 7 octobre 2026. Rapport et registre des lectures.

[4] Agent sans_llm_experiences, *Mesurer la valeur marginale des LLM face à des audits simples : diagnostic de D1 et six expériences hors ligne pour LANCE*, 7 octobre 2026. Rapport et registre des lectures.

[5] NIST, SP 800-115, *Technical Guide to Information Security Testing and Assessment*, septembre 2008, DOI 10.6028/NIST.SP.800-115. PDF officiel. Lecture ciblée des sections 3.3–3.4, pages imprimées 3-2–3-3 ; consultation le 7 octobre 2026, sans lecture intégrale ni reproduction.

[6] NIST, SP 800-53A Rev. 5, *Assessing Security and Privacy Controls in Information Systems and Organizations*, janvier 2022. La notice signale une mise à jour mineure 5.2.0 du 27 août 2025. Notice officielle et PDF. Lecture du paragraphe 2.4, pages imprimées 11–12, et notice, le 7 octobre 2026 ; pas d'affirmation de conformité ou de lecture intégrale de la révision.

[7] D. Lakens, *Equivalence Tests : A Practical Primer for t Tests, Correlations, and Meta-Analyses*, Social Psychological and Personality Science, 8(4), 355–362, 2017, DOI 10.1177/1948550617697177. PDF institutionnel. Lecture introduction et *Testing for Equivalence*, pages imprimées 355–356, le 7 octobre 2026. Transfert méthodologique proposé ; aucun test LANCE exécuté.